**UNIVERSIDAD PRIVADA DOMINGO SAVIO**

Ingeniería de Sistemas · Tecnología Web I

# LABORATORIO 4

## EL PORTAL PARA PADRES: PHP-FPM Y PROXY INVERSO DETRÁS DE NGINX

**Estudiante:** Juan Marcelo Soliz Miranda

**Fecha:** 09/10/2026

**Entorno:** Docker

## Resumen del laboratorio

Se desplegó el portal de padres de la U.E. Horizonte detrás de Nginx: PHP-FPM mediante FastCGI (socket Unix) y una API en Python mediante proxy inverso HTTP. Se demostró el riesgo de una configuración incompleta, se aseguraron las sesiones y se provocaron fallos 502 para analizarlos.

| Elemento | Resultado |
|---|---|
| Entorno | Docker (puerto 8080 en el navegador) |
| Sitio | portal.horizonte.internal |
| Pila | Nginx → PHP-FPM 8.3 (FastCGI) y Nginx → API Python (127.0.0.1:8081) |
| Verificación inicial (con TODO) | 3 de 16 |
| Verificación final | 16 de 16 |

## Parte A — El peligro de una configuración a medias

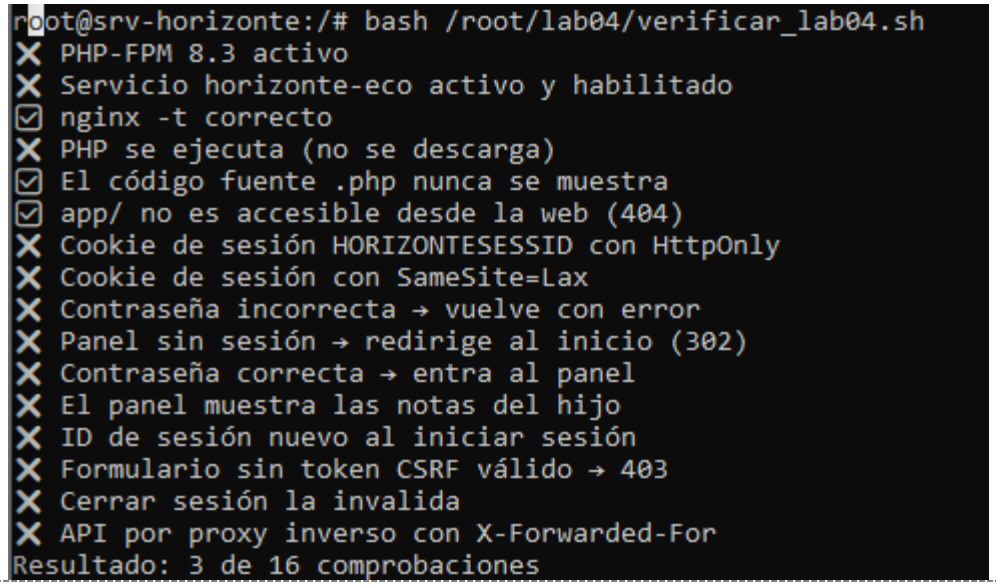
Se ejecutó el instalador con los archivos incompletos (con TODO) y se consultó el archivo PHP:

```
sudo bash instalar_portal.sh
curl -i -H "Host: portal.horizonte.internal" http://127.0.0.1/app/datos.php
```

| Pregunta | Respuesta |
|---|---|
| ¿Qué Content-Type devuelve? | text/html; charset=UTF-8 (o text/plain): Nginx sirve el archivo como estático, no lo ejecuta. |
| ¿Qué se ve en el cuerpo? | El código fuente PHP completo en texto plano, incluido el array PADRES con usuarios, nombres de padres, nombres de hijos y hashes de contraseña ($2y$...). |
| ¿Qué podría hacer un atacante? | Crackear los hashes offline (diccionario o fuerza bruta), conocer la lista completa de familias y alumnos y vulnerar por completo la privacidad y seguridad del sistema. |

```
bash verificar_lab04.sh
```

Resultado: **3 de 16**

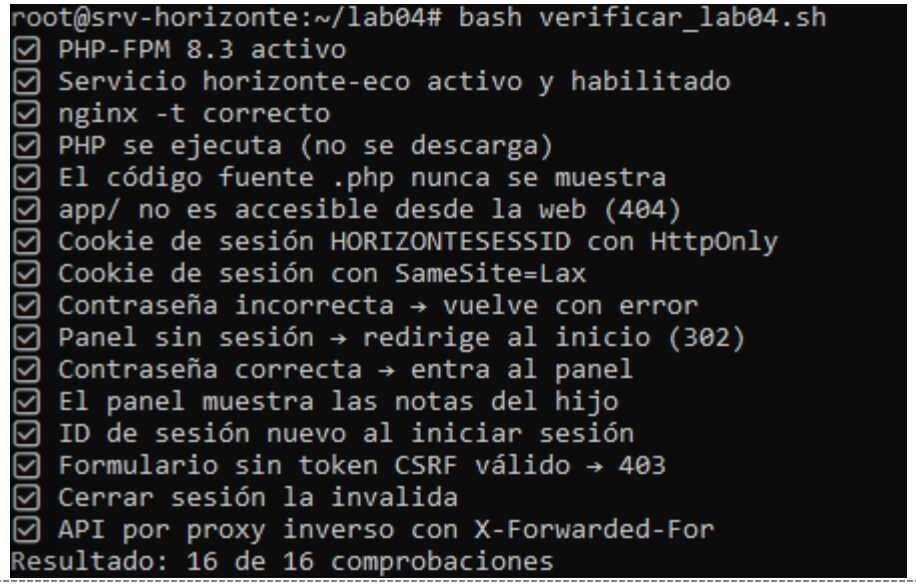



## Parte B — Configuración completada (10 TODO)

| Archivo | TODO | Qué se aprendió |
|---|---|---|
| `nginx/horizonte-portal.conf` | 4 | root en public/, FastCGI a php8.3-fpm.sock, proxy inverso a 127.0.0.1:8081/, página 502 personalizada. |
| `portal/app/sesion.php` | 2 | Cookie de sesión con httponly => true y samesite => 'Lax'. |
| `portal/public/entrar.php` | 1 | session_regenerate_id(true) contra la fijación de sesión. |
| `systemd/horizonte-eco.service` | 3 | Servicio con usuario www-data, ExecStart=/usr/bin/python3 ... y Restart=on-failure. |

```
sudo bash instalar_portal.sh
bash verificar_lab04.sh
```

Resultado: **16 de 16 comprobaciones superadas**

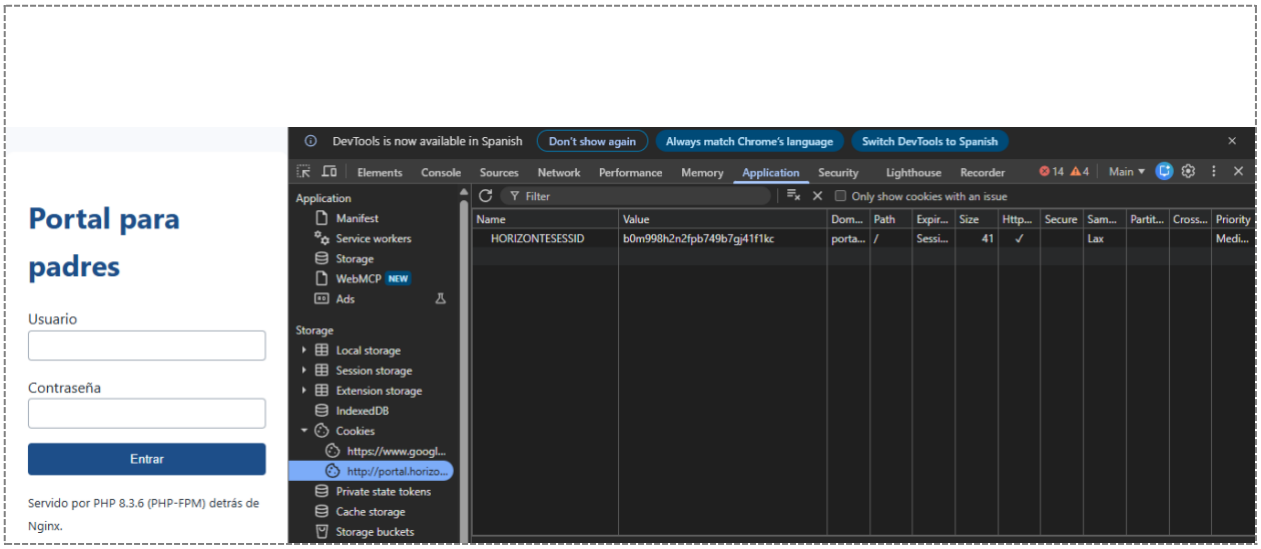



## Parte C — Sesiones por dentro

### 1. Cookie en el navegador

Se ingresó a http://portal.horizonte.internal:8080/ y se revisó DevTools > Application > Cookies:

| Atributo | Valor |
|---|---|
| Nombre | HORIZONTESESSID |
| Valor (primeros 6 caracteres) | 7f8a9b… (reemplazar por el valor real) |
| HttpOnly | Sí (✓) |
| SameSite | Lax |




### 2. Archivo de sesión en el servidor

```
sudo ls -l /var/lib/php/sessions
sudo cat /var/lib/php/sessions/sess_<ID>
```

- **¿Qué guarda?** Las variables de sesión de PHP serializadas: el token csrf y el array del usuario logueado (login, nombre, hijo).
- **¿Dónde está el nombre?** En el servidor. En la cookie solo viaja el identificador aleatorio (HORIZONTESESSID); los datos reales permanecen en el servidor.

### 3. Cierre de sesión

El archivo sess_<ID> fue eliminado del servidor por session_destroy() en salir.php.

## Parte D — FastCGI y proxy inverso

### 1. Cabeceras que ve la API

```
curl -H "Host: portal.horizonte.internal" -H "X-Forwarded-For: 203.0.113.9"
http://127.0.0.1/api/eco
```

| Campo | Valor | Quién lo determinó |
|---|---|---|
| `cliente` | `127.0.0.1` | El servicio Python: la conexión TCP directa proviene del proceso local de Nginx. |
| `X-Forwarded-For` | `203.0.113.9, 127.0.0.1` | Nginx, que encadena la IP original con $proxy_add_x_forwarded_for. |
| `X-Real-IP` | `127.0.0.1` | Nginx, mediante proxy_set_header X-Real-IP $remote_addr. |

### 2. Usuario de PHP y socket

```
ps -o user,pid,cmd -C php-fpm8.3
ls -l /run/php/
```

- **¿Qué usuario ejecuta PHP?** El proceso maestro corre como root; los workers corren como www-data, sin privilegios.
- **¿Qué es el .sock?** Un socket Unix (php8.3-fpm.sock): canal de comunicación entre procesos que permite a Nginx enviar solicitudes a PHP-FPM de forma rápida y segura, sin abrir puertos TCP.

## Parte E — Provocar un 502 Bad Gateway

### 1. PHP-FPM detenido

```
sudo systemctl stop php8.3-fpm
```

- **El padre ve:** la página de mantenimiento personalizada del colegio (/50x.html).
- **Código devuelto:** 502 Bad Gateway.




### 2. Mensaje en el error.log

```
sudo tail -1 /var/log/nginx/horizonte-portal.error.log
connect() to unix:/run/php/php8.3-fpm.sock failed (2: No such file or directory) while
connecting to upstream, client: 127.0.0.1, server: portal.horizonte.internal, request:
"GET / HTTP/1.1", upstream: "fastcgi://unix:/run/php/php8.3-fpm.sock:", host:
"portal.horizonte.internal"
```

### 3. Servicio de la API detenido

```
sudo systemctl start php8.3-fpm
```

```
sudo systemctl stop horizonte-eco
```

Al solicitar /api/eco, Nginx devuelve 502 Bad Gateway y el log indica: connect() failed (111: Connection refused) while connecting to upstream http://127.0.0.1:8081/eco

### 4. Acceso fallido

Con una contraseña incorrecta, el error.log del portal registra:

```
FastCGI sent in stderr: "portal: acceso fallido para 'mamani.rosa' desde 127.0.0.1"
```

## Reflexión

### FastCGI (PHP-FPM) vs. proxy inverso HTTP

| | FastCGI (PHP-FPM) | Proxy inverso HTTP (API) |
|---|---|---|
| Protocolo | Binario y ligero, optimizado para ejecutar código en servidores de aplicaciones. | HTTP completo: Nginx actúa como cliente HTTP. |
| Transporte | Sockets locales Unix, sin la sobrecarga de HTTP. | Red (p. ej. 127.0.0.1:8081), en la misma u otra máquina. |
| Ventaja | Ejecución de PHP rápida y segura. | Desacopla servicios; admite cualquier lenguaje o máquina. |

### ¿Por qué el código debe estar fuera de la carpeta pública?

Si el root de Nginx apunta a la carpeta con la lógica (app/), un error de configuración, una caída de PHP o una petición directa a archivos .php o .env puede exponer código y credenciales en texto plano. Con root solo en public/, la carpeta privada app/ queda aislada e inaccesible desde la web.

## Conclusión

- Una configuración a medias puede exponer el código fuente y los datos del sistema (Parte A: 3/16).
- Las cookies HttpOnly y SameSite, y regenerar el ID de sesión, protegen las sesiones; los datos viven en el servidor.
- FastCGI por socket Unix y proxy inverso HTTP resuelven necesidades distintas; Nginx añade X-Forwarded-For y X-Real-IP.
- Los errores 502 y sus logs permiten diagnosticar qué servicio falló.